菲菲 安全自评

v1.2 本机模拟原型 提交版20261028 2026年10月28日

提交版标识：20261028。本机模拟银行，所有验证与订单均为演示。对应测试与版本记录见《测试与复现》，不把本机测试当作生产认证。

威胁与后端约束

威胁	约束	状态
诱导转账	风险分绿/黄/红，红需绑定挑战	已实现
丢响应重复扣款	UNKNOWN只读，不取消、不重试	已实现
跨站伪造	session、CSRF/Origin、owner证明	已实现
暂停被冒充授权	暂停只改目标元数据	已实现
代码执行越权	无imports的WASM worker，限资源	已实现
外部消息越权	渠道消息只生成草稿	已实现

菲菲从不批准资金操作，确认和验证都在Bank事务内由本人独立完成。日累计额度包含在途金额。演示口令在服务器用PBKDF2校验，不回显原文。

身份与来源

operator只在本地演示交接，有审计、撤销和时间窗；operator的回复永远不会改变UNKNOWN状态。挑战验证码246810是固定的本机演示值，不是真实MFA，也没有接短信、人脸或Ukey。I2渠道使用HMAC、防重放和入站收件箱，转述的消息只作为草稿，不代表权限。

代码生成默认未连接。来源hash绑定worker，一次性token执行前需CAS claim；结果不能用来授权金融动作。

渠道消息带入对话时只作为草稿；长期记忆只保存用户明确要求的笔记，拒绝密钥、验证码等秘密。演示账户与测试样例使用模拟数据；未进行模型参数训练，也不把公开数据等同于已获再利用授权。

模型设置与密钥

首页设置只在服务器显式开启且当前为demo会话时可保存，校验CSRF和Origin；地址固定DeepSeek官方HTTPS。密钥只写本机.env，不回显、不存浏览器或日志，错误信息不带原输入。保存后重启生效，不自动调用模型。公开版本没有密钥。该能力限本机演示，不是生产管理员身份认证。

已知风险

- 未接真实银行、商户、MFA和外部IM。
- 规则只覆盖有限口语、错字和改口；金额不清时先澄清，一次只问一件事，无语音识别。
- 50例80流程合成回归通过，但不是真实反诈检测。
- 已有本机回归及源码审查不构成生产安全认证，真实银行接入仍需独立验证。
- 当前成功查询重放仅回读原子操作；目标停止或风险变化时不续接旧子操作。金额/虚假事实规则是保守启发式，存在漏判与误拦截风险。
- 花与蛋糕重报价后重新选择，付款仍需独立确认；真实商户目录和配送未接。

需人工核验

- 用户：确认金额和收款方，保管验证码。
- 队伍：真实接入的授权、隐私和安全验收。
- 开发核验：当前提交版测试、构建与材料检查结果见《测试与复现》。

回归范围

完整银行后端回归2614项通过、1项跳过（首页设置模块加入前）；设置模块32项通过、1项因Windows无法创建符号链接而跳过；集成后API、会话、规划与目标相关回归121项通过。以上测试组存在重叠，不能相加。全部前端500项通过，TypeScript与Vite构建通过。真实银行、短信、人脸及外部IM未接入。

可编辑内容与代码位于项目仓库；本文件用于参赛技术评审。

项目源代码与说明